

Security+ 3.2 · Firewall Types

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.2 — Firewall Types (8:00)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Evolução: ACL stateless; stateful (lembra a conexão); NGFW (aplicação+user+threat intel+SSL inspection); UTM (NGFW+IPS+AV anti-spam num appliance); WAF (protege o HTTP/S do site: SQLi/XSS/CSRF).

Highlights que a prova cobra

- Stateful lembra a conexão; stateless é por pacote
- NGFW = stateful + aplicação + usuário + threat intelligence
- WAF (L7) protege o web app; NGFW protege o tráfego da rede

Dicas de prova & Cenários Típicos

- 'application-aware firewall'=NGFW
- 'inspects HTTP for SQL injection'=WAF

Cenário clássico de exame: 'application-level firewall for the web server'=WAF.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 3.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Firewall Types) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Modelos de Responsabilidade Compartilhada na Nuvem:**
 - **IaaS (Infrastructure as a Service):** provedor cuida da infraestrutura física/hipervisor; cliente cuida de SO, patches, middleware, rede e dados.
 - **PaaS (Platform as a Service):** provedor cuida do hardware, SO e runtime; cliente cuida do código da aplicação e dos dados.
 - **SaaS (Software as a Service):** provedor gerencia tudo; cliente é responsável apenas pelas configurações de acesso e segurança dos próprios dados.
- **Segmentação de Rede e Segurança Perimetral:**
 - **DMZ (Demilitarized Zone):** sub-rede perimetral intermediária para servidores públicos (web, mail), isolada da rede corporativa interna por firewalls.
 - **VLANs (Virtual LANs):** isolamento lógico de tráfego na camada 2 para separar departamentos sensíveis (ex: finanças, RH, visitantes).
 - **SASE (Secure Access Service Edge):** convergência de SD-WAN e serviços de segurança em nuvem (CASB, FWaaS, ZTNA) entregues próximos ao usuário.
- **Resiliência e Tolerância a Falhas de Armazenamento:**
 - **RAID 0:** striping sem tolerância a falhas (foco exclusivo em velocidade; perda de 1 disco destrói tudo).
 - **RAID 1:** espelhamento (tolera perda de 1 disco; consome 50% do espaço total).
 - **RAID 5:** paridade distribuída (mínimo 3 discos; tolera falha de 1 disco).
 - **RAID 6:** dupla paridade (mínimo 4 discos; tolera falha simultânea de até 2 discos).
 - **RAID 10 (1+0):** combinação de espelhamento e striping (alta performance e redundância).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- RAID NÃO substitui Backup. Se um arquivo for corrompido, excluído ou criptografado por ransomware, o RAID replica o dado corrompido instantaneamente nos discos espelhados.
- Na nuvem pública, a responsabilidade sobre a classificação e sigilo dos DADOS é SEMPRE do cliente em qualquer modelo (IaaS, PaaS ou SaaS).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A)** Firewall stateful tradicional
- B)** Web Application Firewall (WAF)
- C)** Switch Layer 2
- D)** Hub

2. Diferença entre IDS e IPS:

- A)** IDS detecta e alerta; IPS detecta e BLOQUEIA
- B)** São a mesma coisa
- C)** IDS é de disco; IPS é de rede
- D)** IPS só grava log

3. Qual a principal diferença entre IDS e IPS?

- A)** IDS bloqueia ataques, IPS apenas detecta
- B)** IDS apenas detecta e alerta, IPS pode bloquear ativamente
- C)** IDS é físico, IPS é virtual
- D)** IDS opera em camada 2, IPS em camada 3

4. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Stateful lembra a conexão; stateless é por pacote'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'NGFW = stateful + aplicação + usuário + threat intelligence'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: NGFW = stateful + aplicação + usuário + threat intelligence...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'WAF (L7) protege o web app; NGFW protege o tráfego da rede'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: WAF (L7) protege o web app; NGFW protege o tráfego da rede...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'application-aware firewall'=NGFW'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'application-aware firewall'=NGFW...

8. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "inspects HTTP for SQL injection"=WAF'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'inspects HTTP for SQL injection'=WAF...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "application-level firewall for the web server"=WAF'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'application-level firewall for the web server'=WAF....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Stateful lembra a conexão; stateless é por pacote'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Web Application Firewall (WAF).

✓ **Por que está certa:** WAF opera na camada 7 do modelo OSI, inspecionando tráfego HTTP/HTTPS para proteger aplicações web contra ataques como SQL injection e XSS.

✗ **Por que as outras estão erradas:**

- *Firewall stateful tradicional:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Switch Layer 2:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Hub:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — IDS detecta e alerta; IPS detecta e BLOQUEIA.

✓ **Por que está certa:** IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção.

✗ **Por que as outras estão erradas:**

- *São a mesma coisa:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *IDS é de disco; IPS é de rede:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *IPS só grava log:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) B — IDS apenas detecta e alerta, IPS pode bloquear ativamente.

✓ **Por que está certa:** IDS (Sistema de Detecção de Intrusão) monitora e alerta sobre atividades suspeitas. IPS (Sistema de Prevenção de Intrusão) está posicionado inline e pode bloquear/prevenir ataques automaticamente.

✗ **Por que as outras estão erradas:**

- *IDS bloqueia ataques, IPS apenas detecta:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *IDS é físico, IPS é virtual:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *IDS opera em camada 2, IPS em camada 3:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) C — Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): Stateful lembra a conexão; stateless é por pacote.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: NGFW = stateful + aplicação + usuário + threat intelligence....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): NGFW = stateful + aplicação + usuário + threat intelligence.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: WAF (L7) protege o web app; NGFW protege o tráfego da rede....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): WAF (L7) protege o web app; NGFW protege o tráfego da rede.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'application-aware firewall'=NGFW....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'application-aware firewall'=NGFW.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'inspects HTTP for SQL injection'=WAF....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'inspects HTTP for SQL injection'=WAF.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'application-level firewall for the web server'=WAF.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'application-level firewall for the web server'=WAF..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): Stateful lembra a conexão; stateless é por pacote.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

